

CANLIFAL — FAZ 3 RAPORU: FEATURE FLAGS ENTEGRASYONU + RBAC

Tarih: 2026-08-27

Durum: ☒ Tamamlandı & Checkpoint kaydedildi

Kural: Mevcut uçlar değiştirilmedi; sadece eklemeler yapıldı

1. Yeni Dosyalar

lib/check-feature.ts

Feature flag kontrol kütüphanesi:

- `isFeatureEnabled(flagKey)` — boolean döner, 30sn cache (getCache üzerinden)
- `requireFeature(flagKey)` — flag kapalıysa `NextResponse 403` döner, açıksa `null`
- `getFeatureFlags()` — tüm flagleri döner (admin UI için)
- **Geriye uyumluluk:** DB'de olmayan flag → `enabled=true` (mevcut davranış bozulmaz)

lib/rbac.ts

Merkezi rol tabanlı erişim kontrolü:

- `resolveUser(req)` — dual auth (mobile JWT + web session)
- `requireAuth(req)` — 401 if unauthenticated
- `requireAdmin(req)` — 401/403, ADMIN_ROLES kontrolü
- `requireFullAdmin(req)` — 401/403, sadece admin/yönetici
- `requireRole(req, roles[])` — 401/403, belirtilen rollere göre
- `requireOwnerOrAdmin(req, resourceOwnerId)` — kaynak sahibi veya admin
- Re-export: `isAdminRole`, `isFullAdmin`, `ADMIN_ROLES`, `FULL_ADMIN_ROLES` (admin-utils'dan)

2. Feature Flag Guard Eklenen Uçlar (10 endpoint)

#	Dosya	HTTP	Flag	Guard
1	api/chat/rooms/[roomId]/gifts/route.ts	POST	GIFTS_ENABLED	✓
2	api/live/gift/send/route.ts	POST	GIFTS_ENABLED	✓
3	api/video-streams/route.ts	POST	LIVE_ENABLED	✓
4	api/withdrawals/route.ts	POST	WITHDRAWAL_ENABLED	✓
5	api/chat/rooms/[roomId]/pk/route.ts	POST	PK_ENABLED	✓
6	api/video-streams/pk/route.ts	POST	PK_ENABLED	✓
7	api/live/pk/route.ts	POST	PK_ENABLED	✓
8	api/agency/apply/route.ts	POST	AGENCY_ENABLED	✓
9	api/agency/join/route.ts	POST	AGENCY_ENABLED	✓
10	api/chat/rooms/create/route.ts	POST	VOICE_ROOM_ENABLED	✓

Not: Tüm flagler şu an `enabled=true` (PK, Gifts, Live, Agency, Withdrawal, Voice Room) olarak seed'lendi. Dolayısıyla prod davranışı değişmez — sadece admin panelinden kapama yeteneği eklendi.

3. Henüz Guard Eklenmeyenler (Kapsam Dışı / Gelecek Faz)

Flag	Neden Eklenmedi
TOURNAMENT_ENABLED	/api/tournaments/route.ts sadece GET (listeleme); POST/mutation yok
PHONE_LOGIN_ENABLED	Auth akışı Faz 4'te ele alınacak
LOCATION_ENABLED	Konum özellikleri henüz uygulanmamış
VERIFICATION_ENABLED	Doğrulama sistemi henüz uygulanmamış
MULTI_ACCOUNT_ENABLED	Çoklu hesap kontrolü henüz yok
DISCOVER_ENABLED	Keşfet sayfası sadece okuma

4. İstatistikler

- **Yeni dosya:** 2 (lib/check-feature.ts , lib/rbac.ts)
- **Değiştirilen dosya:** 10 (her biri sadece import + 2 satır guard eklendi)
- **Kırılan endpoint:** 0
- **Build:**  TypeScript + production build başarılı

5. FAZ 4 ÖNERİSİ: RATE LIMITING + IDEMPOTENCY

Spec §7 / §31 / §82 uyarınca:

1. **Merkezi rate limiter** (lib/rate-limit.ts)
 - Bellek içi sliding window (Redis olmadığı için)
 - IP + userId bazlı
 - Şu an sadece 9 handler'da rate limit var → kritik mutation'lara yayılacak
2. **Idempotency katmanı** (lib/idempotency.ts)
 - Şu an sadece 4 uçta var
 - Ödeme, hediye gönderme, para çekme gibi finansal işlemlere eklenmesi
 - Idempotency-Key header desteği
3. **Öncelik sırası:**
 - Rate limit: auth endpoints (önce), gift send, payment, withdrawal
 - Idempotency: payment, gift send, withdrawal

Devam edilsin mi?